

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

MANUALE PRIVACY E PRIVACY INFORMATION MANAGEMENT SYSTEM (PIMS)

GDPR + ISO/IEC 27701:2019 — quadro unificato di gestione privacy in TD

Area 09 – Privacy

Codice	Revisione	Data	Pagine
TD-SGI-MAN003_00	00	04/05/2026	6
Redatto da	Approvato da	Classificazione	Stato
DPO / RSGI	AD – Francesco Epifani	Distribuibile a tutto il personale + estratti per pazienti	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
04/05/2026	04/05/2026	04/05/2026

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

1. Scopo del Manuale

Il presente Manuale Privacy descrive il Privacy Information Management System (PIMS) di Toscana Diagnostica S.r.l., implementato in conformità al Reg. UE 2016/679 GDPR e a ISO/IEC 27701:2019 (estensione di ISO/IEC 27001 per la privacy). Il PIMS integra in un unico framework la governance della privacy, le procedure operative, i controlli tecnico-organizzativi (TOM) e gli strumenti di accountability previsti dal GDPR.

2. Ambito di applicazione e perimetro PIMS

Il PIMS si applica a tutti i trattamenti di dati personali effettuati da TD nei seguenti ruoli:

- Titolare del Trattamento (di norma): TD tratta dati paziente, dati dipendenti, dati fornitori, dati prospect, dati di marketing.
- Contitolare: per accordi con strutture sanitarie partner che condividono finalità del trattamento.
- Responsabile del Trattamento: per servizi forniti a clienti B2B che mantengono la titolarità dei dati paziente.
- Sub-responsabile: per fornitori di TD che trattano dati per nostro conto (cloud provider, SaaS, software).

3. Riferimenti

Riferimento	Pertinenza
Reg. UE 2016/679 (GDPR)	Quadro generale protezione dati personali
D.Lgs. 196/2003 (Codice Privacy)	Norma nazionale di adeguamento
ISO/IEC 27701:2019	PIMS — Privacy Information Management System
ISO/IEC 27001:2022	ISMS — Information Security Management System
ISO/IEC 27018:2019	Privacy in cloud (PII Processor)
Provvedimenti Garante Privacy	Linee guida settore sanitario
Regolamento Sanitario UE 2016/679 art. 9	Categorie particolari (sanitari)
Reg. UE 2022/868 Data Governance Act	Riuso dati per ricerca
EHDS — Reg. UE 2025/...	European Health Data Space (in approvazione)

4. Ruoli e responsabilità privacy

Ruolo	Persona / Funzione	Responsabilità chiave
Titolare del Trattamento	Toscana Diagnostica S.r.l. (legale rappresentante: AD)	Determinazione delle finalità e dei mezzi del trattamento; accountability complessiva
DPO (Data Protection Officer)	Designato esternamente, contratto con consulente	Sorveglianza, consulenza, contatto con interessati e Garante; indipendenza
Responsabili interni del trattamento	Direttore Sanitario, IT Manager, Direttore P&C	Garantire adempimento per il proprio ambito

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

Autorizzati	Tutto il personale operativo (medici, biologi, infermieri, TSLB, accettazione, amministrativi)	Trattamento secondo istruzioni, riservatezza
Responsabili esterni (art. 28)	Cloud provider (AWS, Microsoft), software vendor (LIS, GIPOnext)	Contratto con clausole 28 GDPR; verifica periodica
Sub-responsabili	Fornitori di responsabili (di norma cloud sub-processor)	Catena di responsabilità documentata
Privacy Champions	Referenti di area (1 per ogni area operativa)	Promozione cultura privacy + escalation

5. Inventario dei trattamenti (art. 30 GDPR)

Il Registro dei Trattamenti è mantenuto in formato dinamico ed elenca le seguenti categorie principali:

Macro-categoria	Esempi specifici	Base giuridica principale
Erogazione prestazione sanitaria	Accettazione paziente, esecuzione esami, refertazione	Art. 9.2.h GDPR (finalità di assistenza sanitaria)
Fatturazione e contabilità	Emissione fattura paziente, ASL, azienda	Art. 6.1.c GDPR (obbligo legale)
Marketing diretto	Comunicazioni promozionali a pazienti consenzienti	Art. 6.1.a GDPR (consenso)
Soddisfazione cliente	Survey, NPS, raccolta feedback	Legittimo interesse (art. 6.1.f)
Gestione del personale	Anagrafica, retribuzione, formazione, valutazione	Art. 6.1.b (esecuzione contratto) + 9.2.b (lavoro)
Selezione e recruiting	Gestione candidature, colloqui	Consenso o legittimo interesse
Sorveglianza e sicurezza	Videosorveglianza, access control, log IT	Legittimo interesse (art. 6.1.f) + 9.2.b se sanitario
Anti-frode e antiriciclaggio	Verifica controparti, segnalazioni	Obbligo legale (art. 6.1.c)
Adempimenti Modello 231	Whistleblowing, vigilanza OdV	Obbligo legale (D.Lgs. 24/2023)
Telemedicina e teleconsulto	Sessioni a distanza, video	9.2.h + consenso esplicito
Ricerca scientifica (se applicabile)	Studi osservazionali, raccolta dati anonimizzati	Art. 89 GDPR

6. DPIA — Data Protection Impact Assessment

TD esegue DPIA per i trattamenti ad alto rischio, ai sensi dell'art. 35 GDPR. Trattamenti che richiedono DPIA in TD:

- Trattamenti sistematici di dati sanitari su larga scala (LIS, refertazione).

- Sistemi AI per decisioni di salute o profilazione paziente (rif. PRO085, PLN016).
- Videosorveglianza in aree con presenza pazienti.
- Profilazione di marketing per pazienti (decisioni automatizzate art. 22).
- Telemedicina con registrazione audio/video.
- Trattamento di dati di minori per servizi specifici (medicina sportiva pediatrica).

Le DPIA sono mantenute aggiornate e riviste annualmente o al cambiamento sostanziale del trattamento.

7. Misure tecnico-organizzative (TOM)

Le misure TOM sono coerenti con ISO/IEC 27001/27701 e si articolano in tre categorie:

7.1 Misure organizzative

- Politica Privacy POL001 e Manuale PIMS MAN003.
- Designazione DPO indipendente.
- Privacy Champions per area.
- Formazione obbligatoria privacy + GDPR per tutto il personale (annuale).
- Procedure di gestione interessati (esercizio diritti).
- Procedura data breach (notifica entro 72h al Garante).
- Vendor management con valutazione 28 GDPR di tutti i fornitori (PRO017).

7.2 Misure tecniche

- Cifratura at-rest e in-transit (TLS 1.3, AES-256).
- Pseudonimizzazione e anonimizzazione ove possibile.
- Controllo accessi RBAC + MFA su tutti i sistemi che trattano dati sanitari.
- Log delle attività (audit log) con retention conforme alle policy.
- Backup crittografati separati dalla rete primaria.
- Patch management e vulnerability management (PRO094).
- Network segmentation con DMZ per servizi esterni.
- EDR su tutti gli endpoint, SIEM centralizzato.
- Data Loss Prevention (DLP) attiva.

7.3 Misure di privacy by design e by default

- Data minimization: raccogliamo il minimo dato necessario.
- Default privacy-friendly settings (es. comunicazioni di marketing OFF di default).
- Privacy assessment in tutte le fasi del lifecycle del prodotto/servizio (PRO100 modifiche).

- Architetture privacy-preserving (es. federated learning per AI quando applicabile).

8. Esercizio dei diritti degli interessati

Gli interessati possono esercitare i diritti GDPR (artt. 15-22) tramite i seguenti canali:

- Modulo dedicato sul portale paziente.
- Email a dpo@toscanadiagnostica.it (o pec dedicata).
- Lettera raccomandata alla sede legale.

TD risponde entro 1 mese, prorogabile a 3 in casi complessi con motivazione.

I diritti gestiti sono: accesso, rettifica, cancellazione (con limiti normativi sanitari), limitazione, portabilità, opposizione, revoca consenso, opposizione a decisione automatizzata.

9. Data Breach

- Rilevazione: chiunque rilevi una possibile violazione segnala immediatamente al DPO e all'IT Manager.
- Valutazione: il DPO valuta se si tratta di data breach (criterio art. 4 n. 12 GDPR) e se vi è rischio per gli interessati.
- Notifica al Garante: entro 72h dalla conoscenza, se vi è rischio per gli interessati.
- Comunicazione agli interessati: senza ingiustificato ritardo se rischio elevato.
- Documentazione: registro data breach interno ai sensi dell'art. 33.5 GDPR.
- Coordinamento: con CSIRT (PRO086) e Crisis Management (PRO090).

10. Audit e miglioramento continuo

- Audit interno annuale del PIMS (PRO042).
- Audit esterno biennale del DPO (verifica indipendenza).
- Riesame del Manuale PIMS annuale o al variare di norme/processi.
- KPI privacy nel cruscotto ESG (MOD224 pillar G).
- Target di certificazione ISO/IEC 27701 entro Q4 2027.

11. Riferimenti documentali

Codice	Documento
TD-SGI-POL001	Politica Integrata multinorma
TD-SGI-REG016	Statement of Applicability ISO 27001
TD-SGI-PRO005	Gestione Privacy (procedura operativa)
TD-SGI-PRO086	Cybersecurity Incident Response
TD-SGI-PRO094	Vulnerability Management
TD-SGI-PRO017	Gestione Fornitori (vendor 28 GDPR)
TD-SGI-PRO085	AI Governance (DPIA AI)

TD-SGI-PRO088	ESG nel rapporto con i Pazienti
TD-SGI-PRO090	Comunicazione di Crisi
TD-SGI-PLN013	BCP
TD-SGI-PLN014	DRP

12. Storico delle revisioni

Rev.	Data	Descrizione	Approvazione
00	04/05/2026	Prima emissione: PIMS unificato GDPR + ISO 27701 — ruoli, registro trattamenti, DPIA, TOM, diritti, data breach, audit. Target certificazione 27701 entro Q4 2027.	AD / DPO / RSGI